лекция №7 Виды вредоносных программ и способы защиты

План:

1. Что такое вредоносное ПО?
2. Основные типы вредоносных программ

Пути заражения, симптомы заражения

Современные методы защиты

ГЛАВА 1

Что такое вредоносное ПО?

Вредоносное ПО (malware) — это программы, специально созданные для нанесения вреда устройствам, кражи конфиденциальных данных и нарушения нормальной работы систем.

Такие программы могут шпионить за пользователями, вымогать деньги, использовать ресурсы устройств без ведома владельца и распространяться на другие системы.

Вредоносное ПО — эпидемия без сезона

Круглогодичная угроза

В отличие от гриппа, вредоносные программы атакуют непрерывно, 24 часа в сутки, 365 дней в году

Универсальная опасность

Каждый пользователь и организация могут стать жертвой в любой момент, независимо от размера или отрасли

ГЛАВА 2

Основные типы вредоносных программ

Вирусы

Самовоспроизводящиеся программы

Черви

Самостоятельные распространители

Троянские кони

Маскировка под легитимное ПО

Рансомваре

Вымогательство через шифрование

Шпионское ПО

Скрытый сбор данных

Рекламное ПО

Навязчивая реклама

Руткиты

Мастера маскировки

Кейлоггеры

Запись нажатий клавиш

Как создается вредоносное ПО?

Киберпреступники используют различные языки программирования и методы для создания malware:

Языки программирования

- C/C++ — низкоуровневые вирусы и руткиты
- Python — быстрая разработка эксплойтов
- JavaScript — веб-атаки и фишинг
- Assembly — глубокий системный доступ

Методы разработки

- Эксплуатация уязвимостей (zero-day)
- Обфускация кода для обхода антивирусов
- Полиморфизм — изменение кода при заражении
- Социальная инженерия

Инструменты

- Metasploit — фреймворк для тестирования
- Darknet-форумы — обмен кодом
- Конструкторы malware-as-a-service

Статистика вредоносного ПО: рост угроз

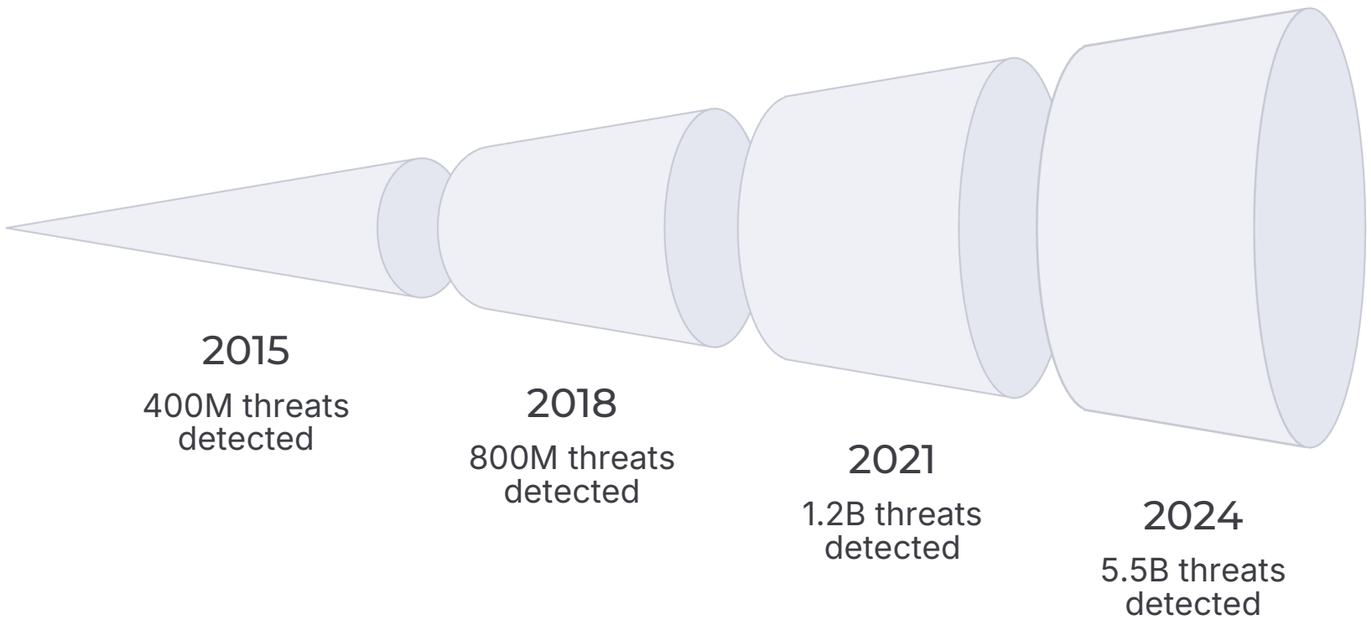
5.5 млрд
Новых угроз в 2024 году

560 000
Новых вирусов ежедневно

43%
Рост ransomware за год

15 мин
Среднее время создания нового варианта

Скорость разработки вредоносного ПО растет экспоненциально благодаря автоматизации и AI-инструментам. Киберпреступники используют конструкторы malware, которые генерируют тысячи вариантов за минуты.



Источники: AV-TEST Institute, Kaspersky Security Bulletin 2024, Statista Cybersecurity Report

ИИ в руках киберпреступников

Искусственный интеллект стал мощным оружием для создания и распространения вредоносного ПО. Злоумышленники используют AI для автоматизации атак и обхода защиты.

Генерация вредоносного кода

ChatGPT и другие LLM помогают писать эксплойты и обфусцировать код, даже если у хакера нет навыков программирования

Фишинг нового уровня

AI создает убедительные письма на любом языке, имитирует стиль письма конкретных людей и компаний

Deepfake-атаки

Подделка голоса и видео руководителей для обмана сотрудников и кражи средств

Автоматизация поиска уязвимостей

AI сканирует миллионы систем в поисках слабых мест быстрее любого человека

Полиморфный malware

ИИ генерирует тысячи вариантов вируса, которые антивирусы не распознают

Социальная инженерия

Анализ соцсетей для создания персонализированных атак на конкретных жертв

Вирусы: невидимые репликаторы

Компьютерные вирусы самовоспроизводятся, заражая другие программы и файлы на устройстве. Они внедряют свой код в легитимные приложения.

- Макровирусы внедряются в документы Word и Excel
- Замедляют работу системы и повреждают файлы
- Требуют действий пользователя для активации

Черви: быстрые распространители

Черви самостоятельно копируются и распространяются по сети без вмешательства пользователя. В отличие от вирусов, они не внедряются в другие программы.

> **WannaCry 2017:** Глобальная атака затронула более 200 000 компьютеров в 150 странах, вызвав массовые сбои в больницах, компаниях и государственных учреждениях

Троянские кони: маскировка и обман

Механизм обмана

Маскируются под легитимное программное обеспечение, заставляя пользователя самостоятельно установить их

Бэкдор-доступ

Открывают злоумышленникам удаленный доступ к системе для кражи данных или установки другого вредоносного ПО

Пример: Emotet

Троян Emotet стал платформой для распространения ransomware и других угроз, нанеся ущерб на миллиарды долларов

Программы-вымогатели (Ransomware)

$20B

Ущерб в 2025

Глобальный ущерб от ransomware превысил $20 млрд

72ч

Средний срок

Время, которое требуют для оплаты выкупа

Ransomware шифрует файлы жертвы и требует выкуп за расшифровку, обычно в криптовалюте. Даже после оплаты нет гарантии восстановления данных.

Colonial Pipeline 2021: Атака парализовала крупнейший топливопровод США, компания заплатила $4.4 млн выкупа

Шпионское ПО: невидимый вор

Сбор данных

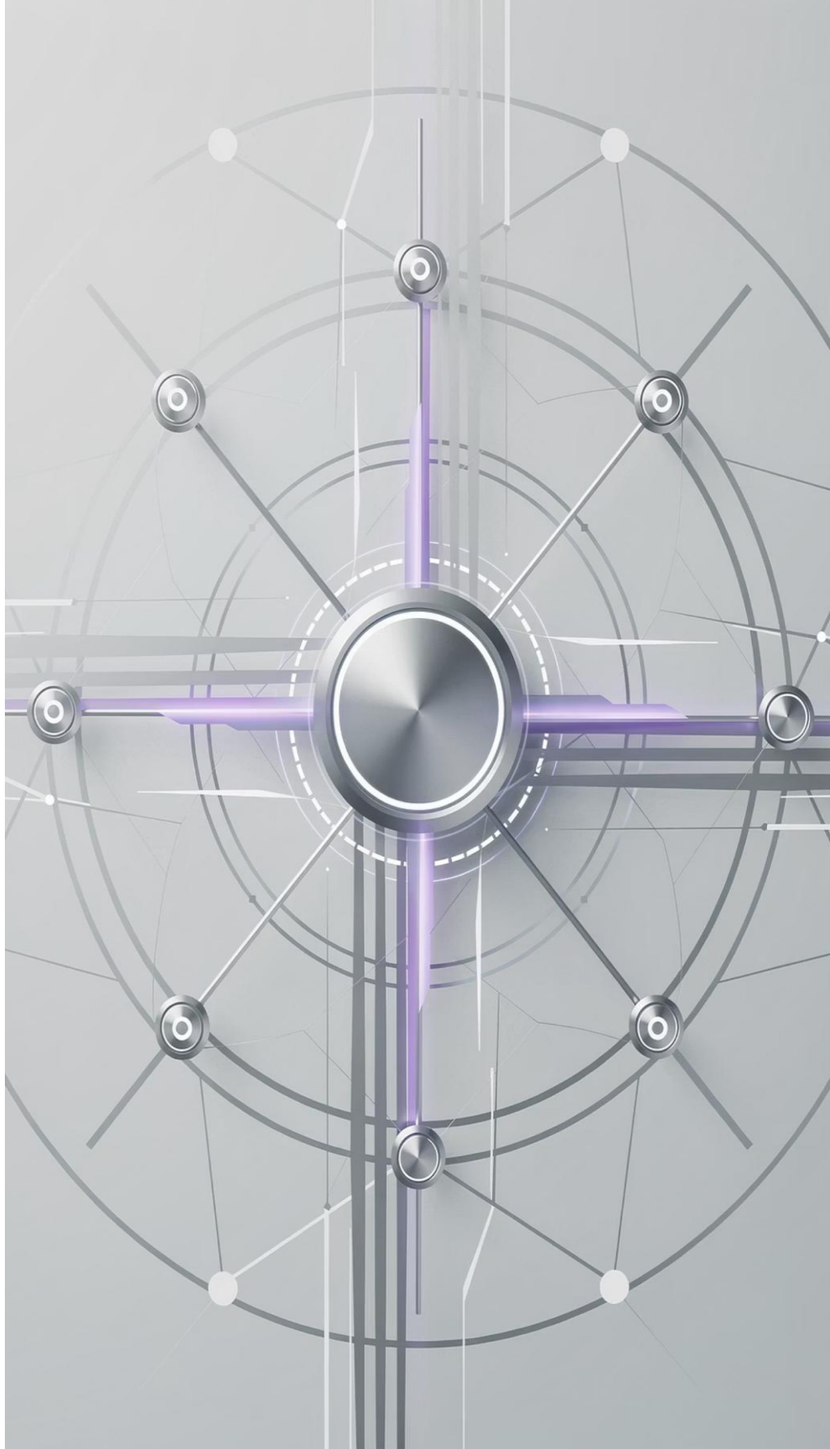
Скрытно собирает пароли, личные данные, историю браузера и финансовую информацию

Кто использует

Применяется как киберпреступниками, так и государственными структурами для слежки

CoolWebSearch

Изменял настройки браузера и отправлял конфиденциальные данные злоумышленникам



Рекламное ПО: навязчивая реклама

Adware **показывает нежелательную рекламу**, **перенаправляет на рекламные сайт**ы и **может собирать данные о поведении пользователей** для таргетированной рекламы.

> **Fireball:** Заразил 250 миллионов компьютеров по всему миру, изменяя домашнюю страницу браузера и поисковую систему

Замедляет работу браузера и создает риски безопасности через перенаправления на зараженные сайты.

Руткиты и буткиты: мастера маскировки

Руткиты скрывают присутствие других вредоносных программ от антивирусов и операционной системы. Буткиты **запускаются еще до загрузки ОС**, что делает их обнаружение крайне сложным. Используются **для длительного незаметного контроля** над системой.

Кейлоггеры: запись каждого нажатия

1

Установка

Устанавливаются скрытно, часто вместе с троянами или через фишинг

2

Запись

Фиксируют каждое нажатие клавиш — пароли, сообщения, данные карт

3

Передача

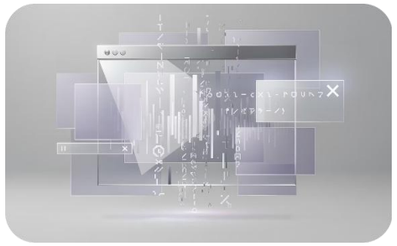
Отправляют собранные данные злоумышленникам для кражи учетных записей

ГЛАВА 3

Пути заражения

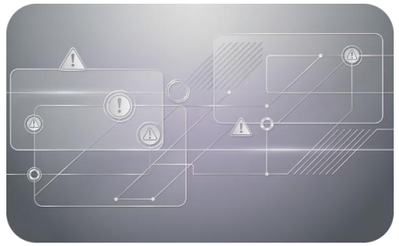
Фишинговые письма

Письма с вредоносными вложениями и ссылками, маскирующиеся под легитимные источники



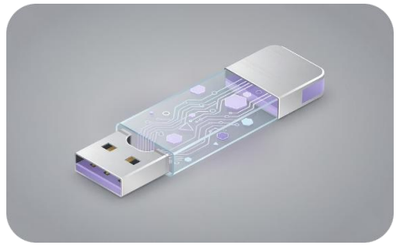
Заражённые сайты

Вредоносная реклама и drive-by загрузки с компрометированных веб-ресурсов



Пиратское ПО

Нелегальные программы и взломанные файлы часто содержат скрытые угрозы



USB-накопители

Заражённые флешки и внешние устройства распространяют malware при подключении

Симптомы заражения: компьютер и сервер

Вредоносное ПО редко проявляет себя открыто — оно стремится оставаться незамеченным как можно дольше. Знание симптомов помогает вовремя обнаружить угрозу.

Явные симптомы

Резкое замедление системы — **CPU/RAM загружены** без видимой причины (майнеры, черви)

Самопроизвольные **перезагрузки и синие экраны (BSOD)** — руткиты, повреждение системных файлов

Появление **неизвестных программ** в автозагрузке и процессах

Браузер перенаправляет на незнакомые сайты, меняется домашняя страница (adware, browser hijacker)

Файлы зашифрованы, появляется требование выкупа (ransomware)

Антивирус отключён или не запускается

Скрытые симптомы

Необъяснимый **исходящий сетевой трафик** в ночное время (C2-коммуникация)

Аккаунты заблокированы или взломаны — кража учётных данных кейлоггером

Неизвестные **задачи в планировщике задач** (Task Scheduler)

Изменения в **реестре Windows** без ведома пользователя

Отключение Windows Defender / брандмауэра

Высокая активность диска без запущенных задач

Симптомы заражения: смартфоны и планшеты

Мобильные устройства всё чаще становятся целью атак. Android более уязвим из-за открытости платформы, iOS — реже, но тоже подвержена угрозам (особенно при джейлбрейке).

Android: признаки заражения

- Резкий разряд батареи и перегрев без нагрузки — **фоновые вредоносные процессы**
- Появление **незнакомых приложений**, которые невозможно удалить
- **SMS и звонки на платные номера** без ведома пользователя
- **Запросы разрешений** от приложений, которым они не нужны (камера, микрофон, контакты)
- Резкий рост потребления мобильного трафика — **шпионское ПО отправляет данные на C2**
- **Всплывающая реклама** даже вне браузера (adware)
- Телефон **медленно работает, зависает, самостоятельно перезагружается**

iOS: признаки заражения

- Необычно **высокое потребление трафика в фоне**
- Приложения **вылетают чаще обычного**
- Устройство **перегревается в режиме ожидания**
- Появление **незнакомых профилей конфигурации** (Настройки → Основные → VPN и управление устройством)
- Браузер Safari **перенаправляет на подозрительные сайты**
- При джейлбрейке: **незнакомые пакеты в Cydia**, изменение системных файлов

Как проверить Android: Настройки → Приложения → проверить разрешения и трафик каждого приложения. Установить антивирус (Malwarebytes, Kaspersky).
Как проверить iOS: Настройки → Конфиденциальность → проверить доступ к камере/микрофону. Удалить неизвестные профили конфигурации.

ГЛАВА 4

Современные методы защиты

Антивирусы

Комплексные решения с AI-защитой, например Kaspersky Premium, ESET, Norton

Обновления

Регулярное обновление ОС и всех программ для закрытия уязвимостей

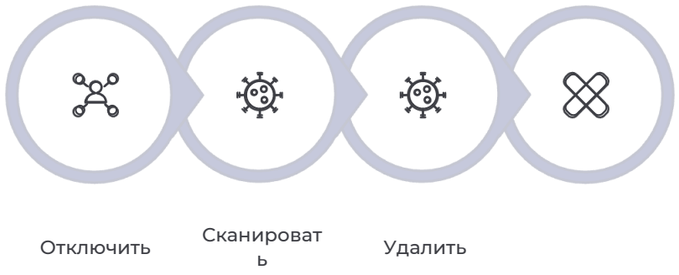
Блокировщики

Использование блокировщиков рекламы и фильтров спама в почте

Обучение

Повышение осведомленности о киберугрозах и основах цифровой гигиены

Реакция на заражение



1 Изоляция

Немедленное отключение зараженного устройства от сети и интернета

2 Сканирование

Полная проверка системы антивирусом и удаление обнаруженных угроз

3 Восстановление

Анализ уязвимостей, изменение паролей, восстановление из резервных копий

Антивирусы: первый рубеж обороны

Современные антивирусные решения обнаруживают и нейтрализуют как известные, так и новые угрозы.

01

Сигнатурный анализ

Сравнение с базой известных угроз

02

Поведенческий анализ

Выявление подозрительных действий программ

03

Искусственный интеллект

Обнаружение ранее неизвестных угроз

Как антивирус обнаруживает угрозы?

Современные антивирусные программы используют многоуровневый подход для защиты, комбинируя различные методы обнаружения вредоносного ПО. Это позволяет выявлять как известные, так и новые, ранее не встречавшиеся угрозы.

Сигнатурный анализ

Сравнение файлов с обширной базой данных известных вредоносных программ по их уникальным "отпечаткам" (сигнатурам).

Эвристический анализ

Поиск признаков подозрительного кода или структуры, которые могут указывать на вредоносную активность, даже если точной сигнатуры нет.

Поведенческий анализ

Мониторинг действий программ в реальном времени. Если программа пытается выполнить опасные действия (например, изменить системные файлы), она блокируется.

Песочница (Sandbox)

Запуск подозрительных файлов в изолированной виртуальной среде, где их поведение можно безопасно изучить, не нанося вреда основной системе.

Облачный анализ

Использование глобальных облачных баз данных и систем искусственного интеллекта для мгновенной проверки файлов и URL-адресов на предмет новейших угроз.

Популярные антивирусы: сравнение

Данные независимой лаборатории AV-TEST (декабрь 2025, Windows 11). Все представленные продукты получили статус «TOP PRODUCT».

Название	Страна	Цена	Особенности
Kaspersky Premium	Россия	Платно	Высокая точность обнаружения, богатый функционал, родительский контроль
Bitdefender Total Security	Румыния	Платно	Лучший по тестам AV-TEST, мощный облачный анализ, VPN
Avast Free Antivirus	Чехия	Бесплатно	Широкий функционал, бесплатная версия, реклама в бесплатной версии
Microsoft Defender	США	Бесплатно	Встроен в Windows, не требует установки, базовая надёжная защита
ESET Security Ultimate	Словакия	Платно	Лёгкий, быстрый, низкая нагрузка на систему, проактивная защита
Malwarebytes	США	Платно/Бесплатно	Специализируется на удалении malware, отличное дополнение к основному антивирусу

Важно помнить, что даже самый лучший антивирус не гарантирует 100% защиты. Соблюдение правил цифровой гигиены и регулярные обновления программного обеспечения остаются ключевыми.

Проактивные меры безопасности

1

Zero Trust

Принцип «Никому не доверяй» — минимальные права доступа для всех приложений и пользователей

2

Резервные копии

Регулярное создание бэкапов для быстрого восстановления данных после атаки

3

Многофакторная аутентификация

Дополнительный уровень защиты учетных записей через 2FA/MFA

Hardening: укрепление системы против атак

System Hardening — процесс уменьшения поверхности атаки путём отключения ненужных функций, ограничения прав и применения политик безопасности. Чем меньше точек входа — тем сложнее вредоносному ПО закрепиться в системе.

Минимизация привилегий

Каждый пользователь и процесс получает только необходимые права, блокируя эскалацию привилегий malware.

Отключение ненужных служб

Деактивация неиспользуемых сервисов (Telnet, SMBv1, RDP при отсутствии необходимости) для уменьшения поверхности атаки.

Политики AppLocker

Разрешение запуска только доверенных приложений, что эффективно блокирует неизвестное вредоносное ПО.

Настройка брандмауэра

Запрет всего входящего трафика по умолчанию, разрешение только необходимых портов и протоколов для защиты сети.

Шифрование дисков

Защита конфиденциальных данных при физическом доступе или краже устройства с помощью BitLocker или FileVault.

Регулярные обновления

Своевременное закрытие известных уязвимостей, таких как EternalBlue или Log4Shell, которые эксплуатирует malware.

Стандарты hardening: CIS Benchmarks, NIST SP 800-123, DISA STIG.

EDR: обнаружение и реагирование на угрозы

EDR (Endpoint Detection and Response) — класс решений для непрерывного мониторинга конечных устройств, обнаружения сложных угроз и автоматического реагирования на инциденты. В отличие от традиционных антивирусов, EDR анализирует поведение, а не только сигнатуры.

Как работает EDR

Сбор данных

Агент на устройстве собирает логи процессов, сетевых соединений, файловых операций в реальном времени

Поведенческий анализ

Алгоритмы ML выявляют аномалии: нетипичные запуски процессов, обращения к реестру, lateral movement

Корреляция событий

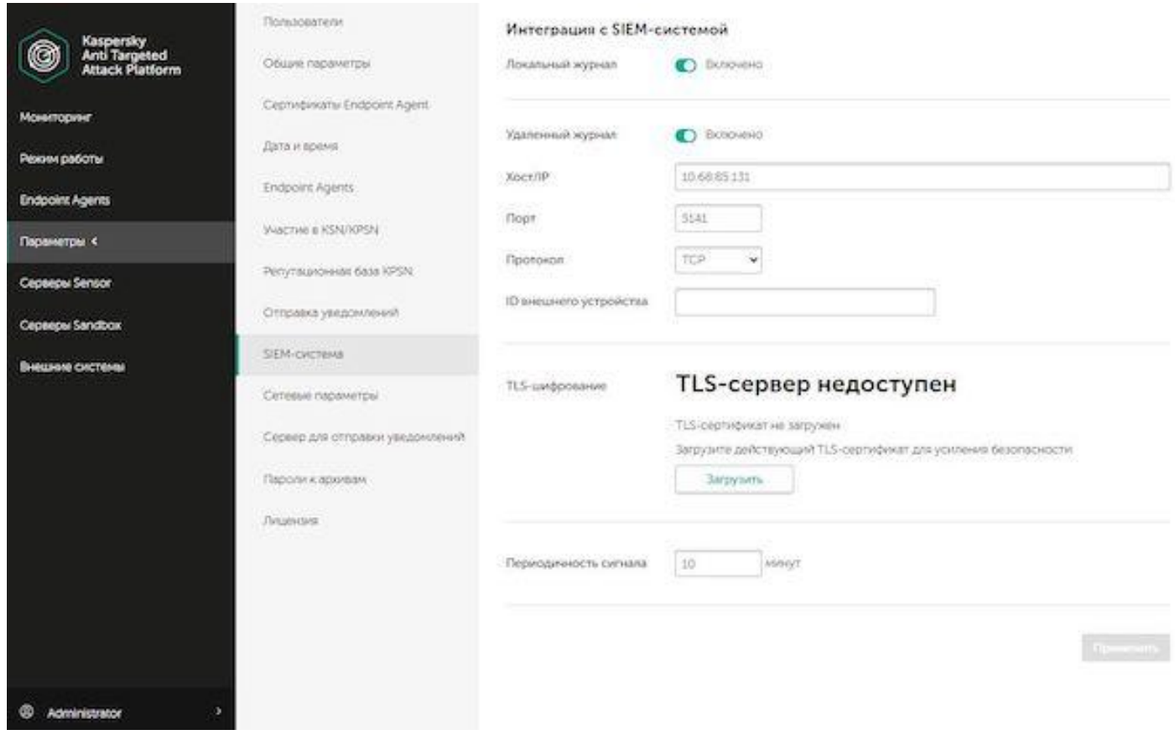
События сопоставляются с базой тактик MITRE ATT&CK для идентификации атак

Автоматическое реагирование

Изоляция устройства, завершение вредоносных процессов, откат изменений

Настройка для обнаружения malware

- Включить мониторинг всех процессов и дочерних процессов
- Настроить правила обнаружения по MITRE ATT&CK (T1059 — выполнение скриптов, T1055 — инъекция процессов)
- Установить пороги аномалий для сетевого трафика
- Настроить автоматическую изоляцию при обнаружении ransomware-поведения
- Интегрировать с Threat Intelligence для получения актуальных IoC



Популярные EDR-решения: CrowdStrike Falcon, Microsoft Defender for Endpoint, SentinelOne, Kaspersky EDR.

изоляция зараженных узлов,
завершения процессов,
удаления файлов,
выполнения произвольных команд,
централизованный сбор
дополнительного контекста,
проверки файлов по хешам,
перенаправления сетевых
соединений,
дополнительного анализа файлов

XDR: расширенное обнаружение угроз

XDR (Extended Detection and Response) — это эволюция EDR. Если EDR видит только конечные устройства, XDR объединяет данные из всех уровней инфраструктуры: endpoints, сеть, email, облако, серверы — и коррелирует их в единой платформе, видя атаку целиком.

EDR vs XDR: в чём разница

	EDR	XDR
Охват	Только endpoints	Endpoints + сеть + email + облако
Видимость	Частичная	Полная цепочка атаки
Корреляция	В рамках устройства	Кросс-источниковая
Реагирование	На уровне хоста	На всех уровнях сразу
Сложность	Ниже	Выше, но эффективнее

Как XDR обнаруживает malware

Сбор телеметрии

Данные с endpoints (процессы, файлы), сети (DNS, трафик), email (фишинг), облака (API-вызовы) собираются для анализа.

Унификация данных

Все источники приводятся к единой модели данных для сквозного анализа, обеспечивая согласованность информации.

Кросс-источниковая корреляция

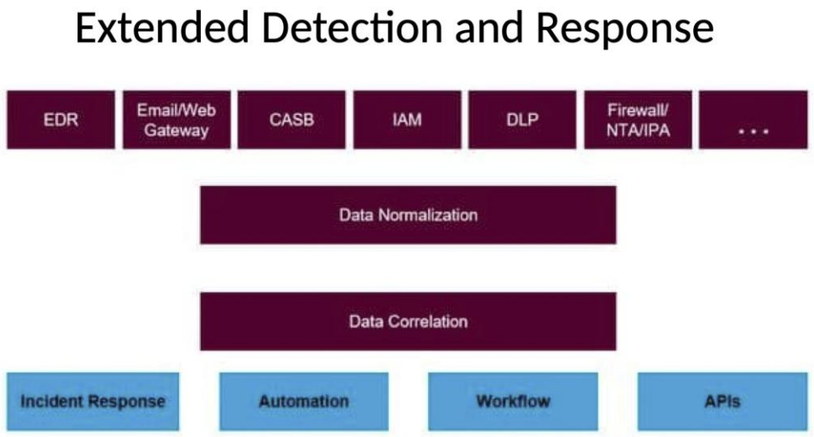
XDR видит полную цепочку: фишинг → заражение endpoint → lateral movement → C2-коммуникация → exfiltration, сопоставляя события.

Автоматическое реагирование

Блокировка на всех уровнях одновременно: изоляци хоста + блокировка IP + карантин письма для быстрого сдерживания угрозы.

Threat Hunting

Проактивный поиск скрытых угроз по всей инфраструктуре, выявление индикаторов компрометации до их активации.

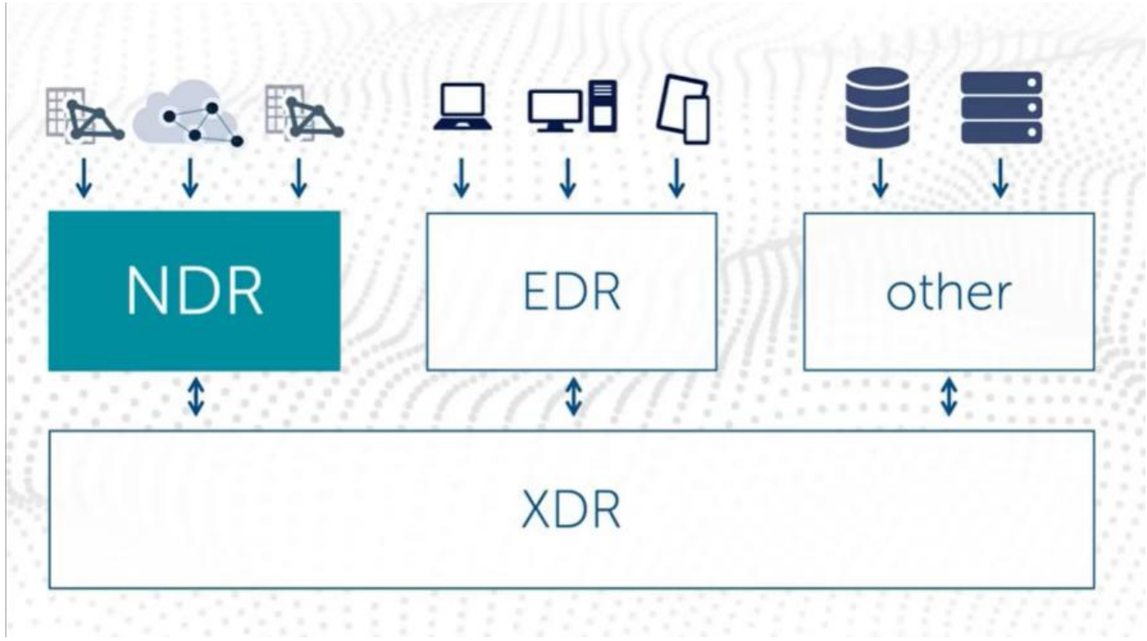


Пример: WannaCry через XDR — email с вредоносным вложением (email layer) → запуск на хосте (endpoint layer) → распространение через SMB (network layer). XDR видит всю цепочку и блокирует на каждом этапе.

Популярные XDR-решения: Microsoft Defender XDR, CrowdStrike Falcon XDR, Palo Alto Cortex XDR, SentinelOne Singularity XDR.

При выборе XDR эксперты выделили несколько ключевых моментов, образующих комплекс: детектирование и расследование — это основа; важно удобство расследования, потому что накапливается огромное количество логов; имеет значение поддержка большого количества операционных систем.

EDR, XDR находят все точки входа хакера и рисует всю цепочку атак.
Продукт находит точку активности и простраивает все что делал хакер



Решения класса EDR и XDR позволяют

- Защитить самые популярные точки входа злоумышленников
- Визуализировать цепочку атаки, чтобы найти точку входа
- Централизованно визуализировать события ИБ со всех компонентов XDR
- Анализировать события с конечных устройств
- Использовать как инструмент изоляцию станций, удаление файлов, поиск индикаторов компрометации, завершение процессов, запуск скриптов, получение дампов памяти и др
- Сокращать время на расследование инцидентов
- Подключать динамические методы анализа
- Обогащать информацией за счет интеграции с Threat Intelligence Platform
- Интегрировать со сторонними системами

SIEM: централизованный мониторинг угроз

SIEM (Security Information and Event Management) — система, которая собирает, агрегирует и анализирует логи со всей инфраструктуры в реальном времени. Позволяет обнаруживать атаки, которые незаметны на уровне отдельных устройств.

Как SIEM обнаруживает malware

Сбор логов

Агрегация событий из всех источников: серверы, рабочие станции, сетевые устройства, антивирусы, EDR, облако.

Нормализация

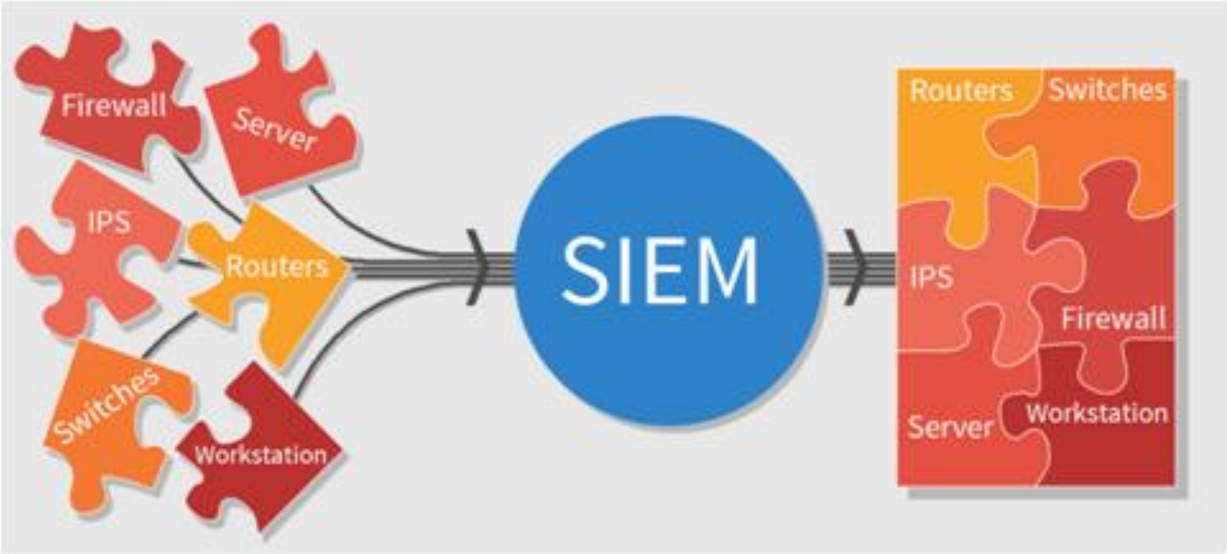
Приведение разнородных логов к единому формату для сравнения и анализа.

Корреляция правил

Применение правил (Use Cases): например, множественные неудачные входы + запуск PowerShell = подозрение на brute force + malware.

Приоритизация алертов

Ранжирование угроз по критичности (Critical / High / Medium / Low).

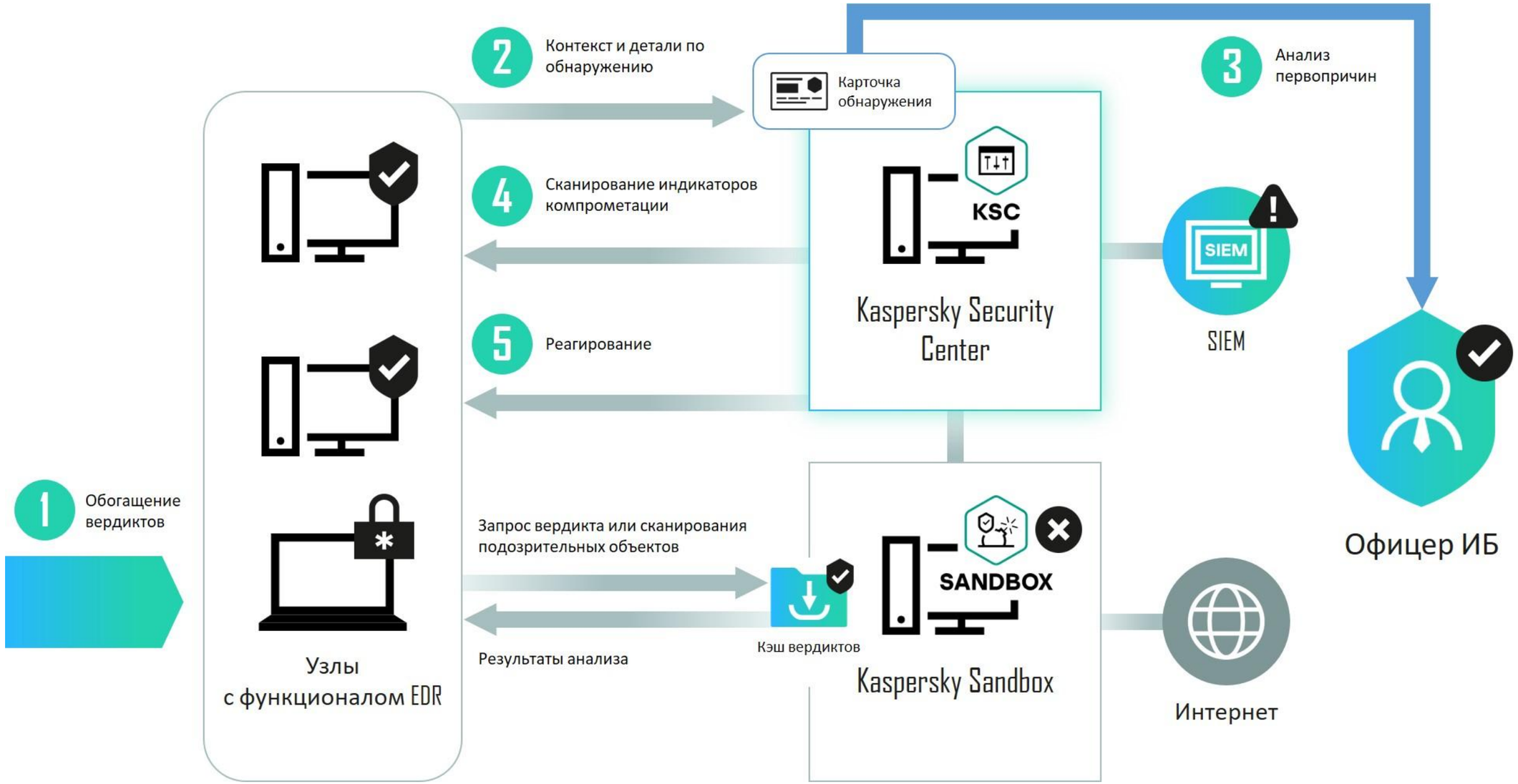


Реагирование

Уведомление SOC-аналитика, автоматический запуск playbook через SOAR.

Популярные SIEM: Splunk, IBM **QRadar**, Microsoft Sentinel**, Elastic SIEM**, **Wazuh** (open-source)

схема взаимодействия



Wazuh: единая платформа безопасности

Wazuh — это бесплатная open-source платформа безопасности, которая объединяет SIEM, EDR и XDR в одном решении. Агент Wazuh устанавливается на каждый хост (Windows, Linux, macOS, Android) и отправляет данные на центральный сервер для анализа.

Что умеет Wazuh

SIEM
Сбор, агрегация и корреляция логов со всей инфраструктуры

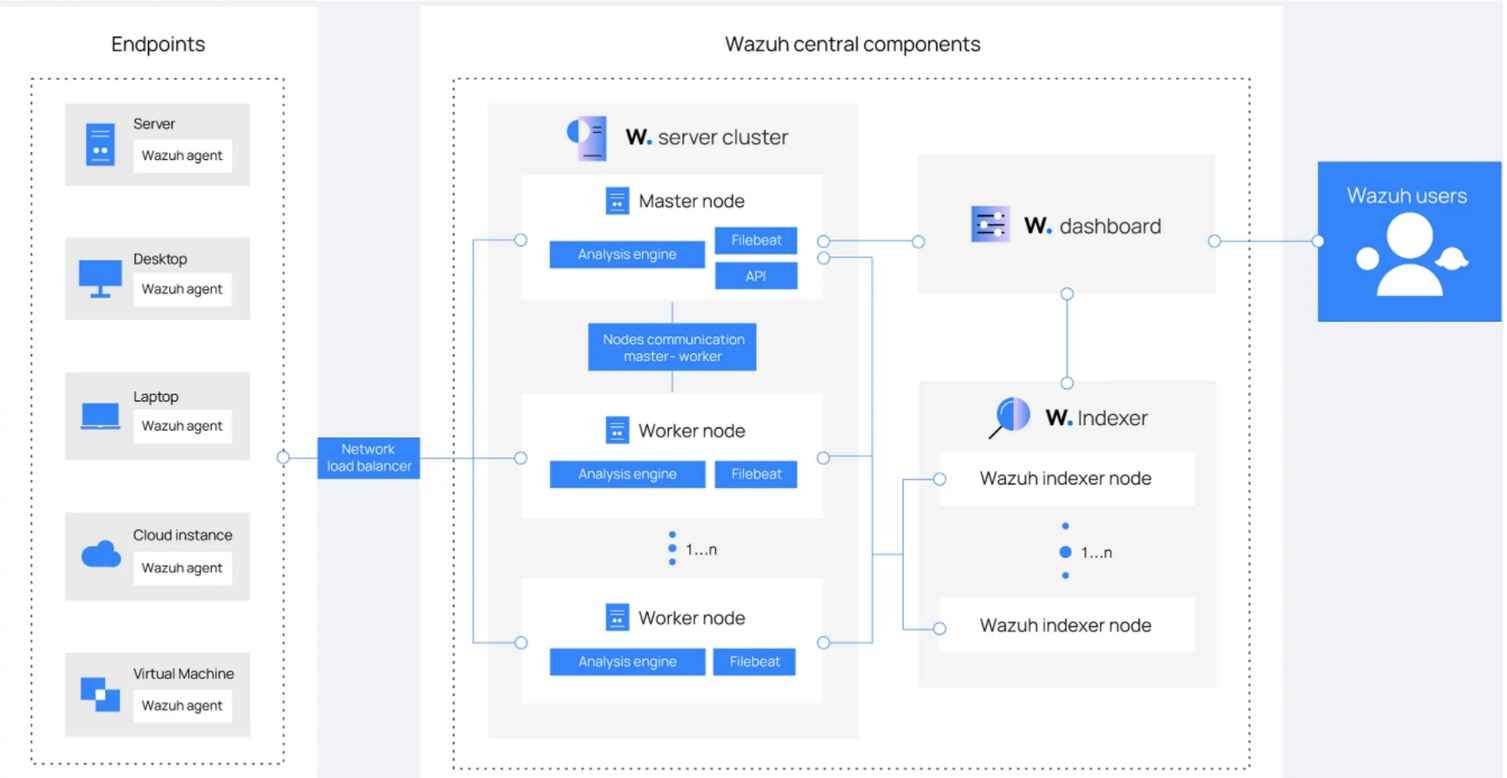
EDR
Агент мониторит процессы, файлы, сетевые соединения в реальном времени

XDR
Расширенное обнаружение угроз across endpoints, cloud, network

File Integrity Monitoring (FIM)
Отслеживание изменений критических файлов и реестра

Vulnerability Management
Автоматическое сканирование уязвимостей на хостах

Compliance
Готовые правила для PCI DSS, HIPAA, GDPR, NIST

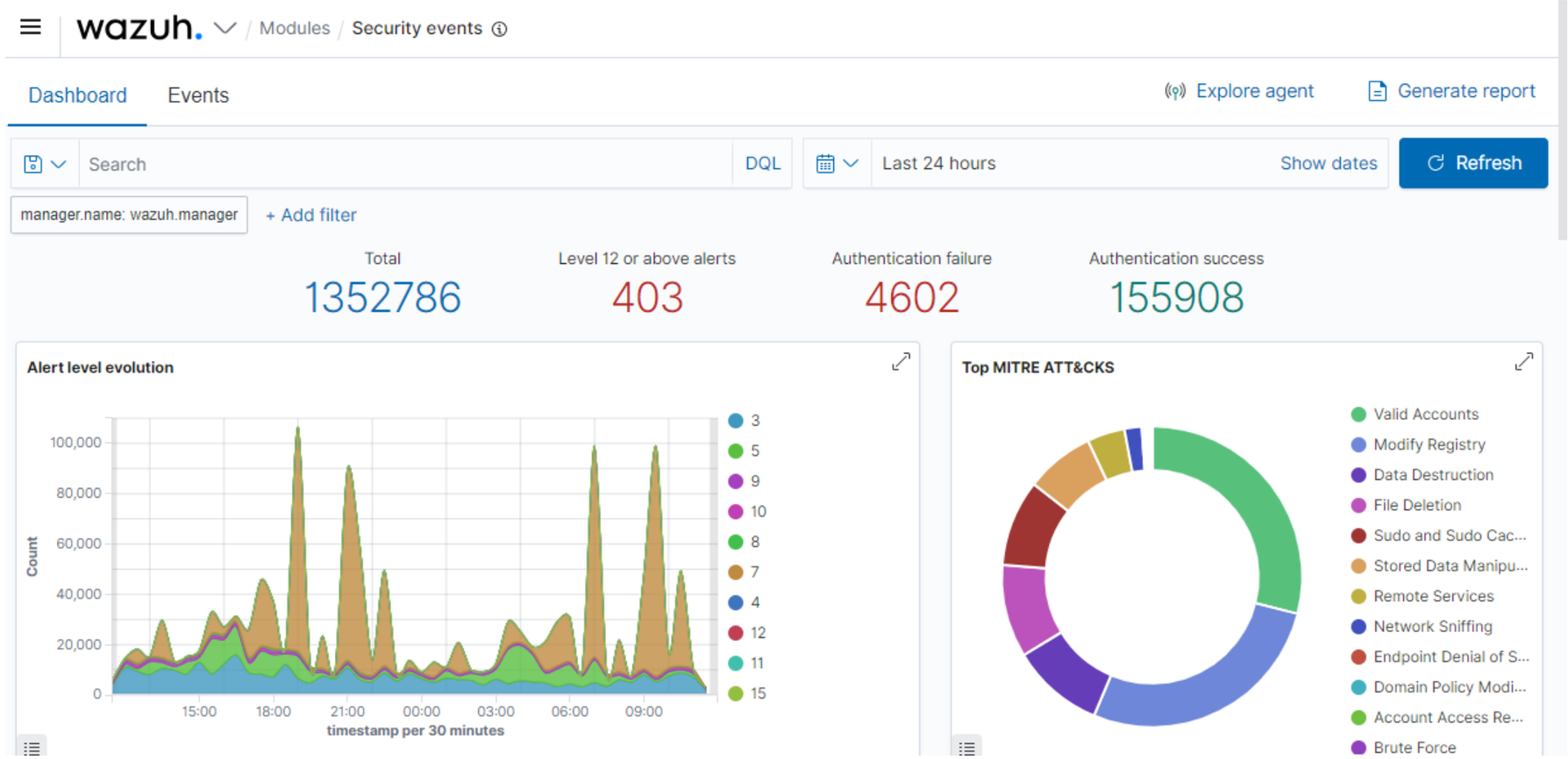


Источник: wazuh.com

	Minimum		Recommended	
Component	RAM (GB)	CPU (cores)	RAM (GB)	CPU (cores)
Wazuh indexer	4	2	16	8
Wazuh server	2	2	4	8
Wazuh dashboard	4	2	8	4

Настройка для обнаружения malware

- **Установить агент** на каждый хост: Windows (Event Log, Sysmon), Linux (/var/log, auditd), macOS
- **Включить FIM:** мониторинг C:\Windows\System32, реестра HKLM\Software\Microsoft\Windows\CurrentVersion\Run — типичные места закрепления malware
- **Активировать правила MITRE ATT&CK:** Wazuh имеет встроенный маппинг правил на тактики ATT&CK
- **Настроить active response:** автоматическая блокировка IP, завершение вредоносных процессов при срабатывании алерта
- **Интегрировать с VirusTotal API:** автоматическая проверка хешей новых файлов на malware
- **Подключить OpenSearch/Kibana** для визуализации дашбордов и расследования инцидентов



OpenSearch Security Analytics: SIEM с открытым кодом

OpenSearch Security Analytics — это встроенное SIEM-решение на базе OpenSearch (open-source форк Elasticsearch от AWS). Предназначено для обнаружения, расследования и реагирования на угрозы в реальном времени. Устанавливается автоматически с любым дистрибутивом OpenSearch.

Ключевые компоненты

Детекторы (Detectors)

Настраиваемые компоненты, которые анализируют лог-данные и сопоставляют события с тактиками MITRE ATT&CK

Правила обнаружения (Sigma Rules)

2200+ готовых open-source правил в формате Sigma; можно создавать собственные

Findings (Находки)

Каждое совпадение правила с событием фиксируется как Finding с уровнем критичности

Correlation Engine

Сопоставляет находки из разных источников логов, выявляя цепочки атак

Алерты

Уведомления в Slack, email, Amazon Chime при срабатывании правил

Настройка для обнаружения malware

- **Подключить источники логов:** Windows Event Log, DNS logs, Sysmon, firewall, CloudTrail, network logs
- **Создать детектор:** выбрать тип лога → система автоматически подберёт подходящие Sigma-правила
- **Активировать правила malware:** включить правила для T1059 (выполнение скриптов), T1055 (инъекция процессов), T1486 (шифрование файлов — ransomware)
- **Настроить корреляцию:** создать correlation rules для выявления многоэтапных атак (lateral movement + C2 + exfiltration)
- **Настроить алерты:** Critical-алерты → немедленное уведомление SOC; High → тикет в систему

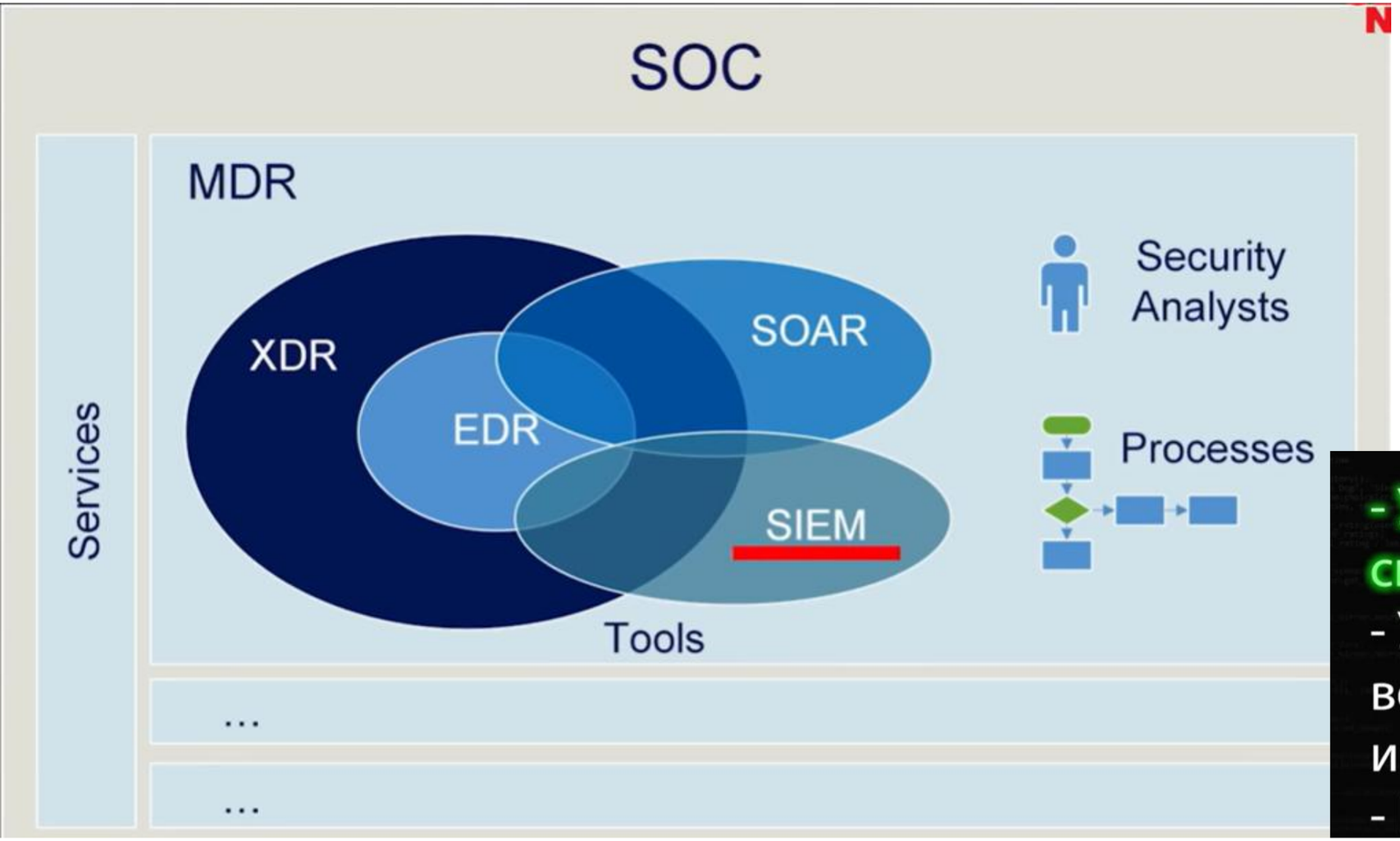
Источник: opensearch.org/platform/security-analytics

Отличие от Elastic SIEM: OpenSearch полностью open-source без лицензионных ограничений, форк Elasticsearch 7.10.

- ОБНАРУЖИЛИ СВОЕВРЕМЕННО И ОТБИЛИ АТАКУ

- ОБНАРУЖИЛИ ПОЗДНО, НО У ВАС УДАЧНОЕ РЕАГИРОВАНИЕ

- НЕ ОБНАРУЖИЛИ, НЕ СРЕАГИРОВАЛИ, НО ПОЛУЧИЛОСЬ ВОССТАНОВИТЬСЯ



- Узнать, ВОВРЕМЯ что у тебя внутри сидят хакеры
- Узнать, что у тебя БУДЕТ возможность восстановиться за приемлемый срок и приемлемые деньги
- Правильно среагировать на атаку

Продукт	Точка установки	Обнаружение	Расследование	Реагирование	Уменьшает ложные срабатывания
EDR	Хост	✓	✓	✓	
NDR	Сеть	✓	✓	✓	
NGFW	Сеть	✓	✓	✓	
XDR	Сеть и хост	✓	✓	✓	✓
SIEM		✓	✓		✓
TIP		✓	✓		
SOAR/IRP			✓	✓	✓

https://www.youtube.com/watch?v=Pikp9gdXQ9c&t=289s

КЕЙСЫ

Уроки из реальных атак

1

Fireball (2017)

250 миллионов заражённых устройств по всему миру. Adware получил полный контроль над браузерами, изменяя поисковые запросы и внедряя вредоносный код

2

WannaCry (2017)

Глобальная ransomware-атака затронула 200 000+ компьютеров в 150 странах, парализовав больницы, транспорт и корпорации. Требование выкупа в биткоинах

3

Colonial Pipeline (2021)

Ransomware-атака остановила крупнейший топливопровод США. Паралич критической инфраструктуры, выкуп $4.4 млн, дефицит топлива на Восточном побережье

Будущее борьбы с вредоносным ПО

AI и машинное обучение

Развитие искусственного интеллекта для раннего обнаружения и автоматического реагирования на новые угрозы

Международное сотрудничество

Усиление координации между странами и организациями в области кибербезопасности

Образование пользователей

Массовое повышение цифровой грамотности и осведомленности о киберугрозах

Защитите себя и свои данные

Реальная угроза

Вредоносное ПО представляет серьезную опасность для всех пользователей, но её можно контролировать

Современные инструменты

Используйте актуальные антивирусы, регулярно обновляйте системы и создавайте резервные копии

Бдительность

Соблюдайте правила цифровой безопасности, будьте внимательны и не давайте шанс злоумышленникам!